

Compliance Policy Pack

Portfolio Project Sample Policies

Includes Incident Response, Data Retention, Access Control, and Vendor Management policies.

Incident Response Policy

- Purpose: Establish procedures for identifying, responding to, and recovering from security incidents.
- Scope: Applies to all systems, employees, contractors, and third-party services.
- Incident Classification: Low, Medium, High, and Critical severity levels.
- Reporting: All suspected incidents must be reported immediately to management.
- Containment: Isolate affected systems to prevent further impact.
- Eradication: Remove malicious code, compromised accounts, or vulnerabilities.
- Recovery: Restore systems from verified backups and monitor for recurrence.
- Post-Incident Review: Document lessons learned and corrective actions.

Data Retention Policy

- Purpose: Define retention and disposal requirements for organizational data.
- Customer Records: Retained for a minimum of 7 years unless otherwise required.
- Audit Logs: Retained for at least 12 months.
- Employee Records: Retained according to applicable labor regulations.
- Data Disposal: Secure deletion methods must be used.
- Backup Retention: Daily backups retained for 30 days; monthly backups for 12 months.
- Legal Hold: Data subject to legal proceedings must not be deleted.

Access Control Policy

- Purpose: Ensure only authorized individuals access systems and information.
- Least Privilege: Users receive only the permissions required for their roles.
- Authentication: Multi-factor authentication required for administrative accounts.
- Password Requirements: Strong passwords with minimum length and complexity.
- Account Reviews: Access reviews conducted quarterly.
- Termination Procedures: Accounts disabled immediately upon separation.
- Privileged Access: Elevated access must be approved and documented.

Vendor Management Policy

- Purpose: Manage risks associated with third-party vendors and service providers.
- Vendor Assessment: Security and privacy reviews performed before onboarding.
- Contract Requirements: Data protection and confidentiality clauses required.
- Risk Classification: Vendors categorized by impact and sensitivity.
- Monitoring: Periodic reviews of vendor performance and compliance.
- Incident Notification: Vendors must notify the organization of breaches promptly.
- Termination: Access and data sharing revoked upon contract termination.